

Table of Contents

Cisco Secure Workload — NERC CIP (North American Bulk Electric System)

Reference Design | Electric Utilities & Generation/Transmission Operators

Version: 1.0 (draft — pending SME review) | **Standards:** NERC CIP-002 through CIP-014 (current effective revisions) | **Audience:** Bulk Electric System (BES) responsible entities and their security teams | **Environment:** IT estate supporting OT (corporate IT, engineering workstations, jump servers, historian/MES tier — *not* the OT control devices themselves)

Reader's Guide

Who this is for. Registered Entities under the NERC Reliability Standards (Generation Owners/Operators, Transmission Owners/Operators, Balancing Authorities, Reliability Coordinators, Distribution Providers where applicable), and the cybersecurity teams preparing them for NERC/Regional Entity audit cycles or for self-certification.

Scope boundary you must understand before reading further. Cisco Secure Workload (CSW) is a workload-protection and segmentation platform for **IT estate** — servers, virtual machines, containers, and cloud workloads. CSW does **not** enforce policy on PLCs, RTUs, relays, IEDs, HMIs, or any other Level 0–2 OT device. CSW's NERC CIP contribution is specifically at the **IT-side of the IT/OT boundary and within the EACMS (Electronic Access Control or Monitoring Systems) and PACS (Physical Access Control Systems) supporting infrastructure** — jump hosts, engineering workstations, historian/MES databases, patch repositories, vendor-access servers, identity/PKI services, and the corporate IT systems that touch BES Cyber System Information (BCSI). Treat anything below the segmented boundary as out of scope for CSW; reference your ICS/SCADA security stack and your physical network architecture for those layers.

Questions this reference design helps you answer:

- *CIP-005-7 R1 (ESP boundary): can I prove that the only inbound and outbound communications to my Electronic Security Perimeter (ESP) go through the documented Electronic Access Points (EAPs), and that no undocumented lateral path exists from corporate IT to the ESP?*
- *CIP-005-7 R2 (Interactive Remote Access, IRA): can I produce evidence that every IRA session terminates at the documented Intermediate System and that no direct corporate-IT-to-ESP pivot is reachable, with a forensic trail per session?*

- *CIP-007-6 R1 (Ports and Services): for every Cyber Asset within an ESP and for the EACMS supporting it, can I show only network- accessible ports and services that are actually needed, and produce the evidence quarterly?*
- *CIP-007-6 R3 (Malicious Code Prevention) and R4 (Security Event Monitoring): can I demonstrate event monitoring at the workload level for at least the EACMS/PACS/PCA tier, and reconstruct the process and flow context of an event?*
- *CIP-010-4 R1 (Configuration Change Management): can I produce an inventory baseline (R1.1) for every Cyber Asset including software installed (R1.1.5) and ports/services (R1.1.4), and detect unauthorised change (R1.5)?*
- *CIP-010-4 R3 (Vulnerability Assessments): can I produce the active vulnerability assessment evidence for High/Medium-impact BES Cyber Systems on the R3.1 cadence, and the paper assessment for low- impact?*
- *CIP-013-2 R1 (Supply Chain Risk Management): for the IT systems that interact with vendor-supplied software, can I show what those systems are actually talking to externally, and detect when that pattern changes?*

What you'll need. Your current CIP-002 BES Cyber System identification list (with high/medium/low impact rating per Attachment 1), your ESP and PSP inventory under CIP-005/006, your EACMS and PACS inventory, your CIP-010 baseline configuration register, and your Cyber Vulnerability Assessment cadence per CIP-010 R3. CSW will augment but not replace these governance artefacts.

Where to start. Section 2 if you are scoping CSW relative to CIP-002 categorisation; sections 3–4 if you are designing the IT-side of the ESP boundary; section 5 if EACMS hardening and IRA evidence are the audit gap; section 6 if CIP-007 ports/services and CIP-010 baseline drift are the open items; section 9 if supply-chain (CIP-013) visibility is the priority.

Important. NERC CIP enforcement actions are issued by the Regional Entities under FERC oversight. Nothing in this reference design substitutes for your CIP Senior Manager's accountability under CIP-003 or for the RSAW/audit response your Regional Entity will request. CSW gives the Senior Manager the *evidence* needed to defend the programme; it does not author the programme.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces

CSW term	Meaning	Why compliance teams care
		drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denials, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- IT-side ESP boundary hardening (CIP-005 R1) — pair with OT tools
- IRA evidence inputs (CIP-005 R2) from access logs
- CIP-007/010 ports + baseline from process-aware telemetry

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

NERC Critical Infrastructure Protection (CIP) Reliability Standards govern cybersecurity for the Bulk Electric System (BES) across North America. The standards apply to Registered Entities and to the BES Cyber Systems they own or operate. The current standards in scope for this reference design are:

Standard	Topic	Coverage	What to file
CIP-002	BES Cyber System Categorization	Partial Coverage	Labelled inventory next to the Attachment 1 decision. Secure Workload does not rate High, Medium, or Low.
CIP-003	Security Management Controls	Partial Coverage	Quarterly IT-side pack for the CIP Senior Manager. Policies and the Senior Manager designation stay with the entity.
CIP-004	Personnel & Training	Evidence Required	Background checks, training, and access revocation. No Secure Workload artifact.
CIP-005	Electronic Security Perimeters & IRA	Partial Coverage	Deny-by-default up to the EAP, plus per-session IRA flows. The EAP firewall, session encryption, and MFA stay outside Secure Workload.
CIP-006	Physical Security	Evidence Required	Physical security perimeter and visitor logs. No Secure Workload artifact.
CIP-007 R1	Ports and Services	Full Coverage	Listening-port inventory with process and last-

Standard	Topic	Coverage	What to file
			flow time, dated at least quarterly, tied to the baseline.
CIP-007 R2	Patch Management	Partial Coverage	CVE and package list. The evaluation, the patch source, and the install record stay with the patch programme.
CIP-007 R3–R4	Malicious code and security events	Partial Coverage	Behavioural-rule record and SIEM telemetry. Endpoint anti-malware and the alert-review log stay with those owners.
CIP-007 R5	System access control	Partial Coverage	Policy limiting which workloads can reach authentication services. Accounts, passwords, and MFA stay with identity.
CIP-008	Incident Reporting & Response	Partial Coverage	Six-artefact reconstruction bundle. The response plan, the test, and the E-ISAC notice stay with the entity.
CIP-009	Recovery Plans	Partial Coverage	Policy and baseline export as a known-good IT-side state. Backup execution and the recovery test stay with DR.
CIP-010 R1	Configuration baseline and	Full Coverage	Daily software and listening-port

Standard	Topic	Coverage	What to file
	change		baseline, diff, and disposition against the change ticket.
CIP-010 R3	Vulnerability assessment	Partial Coverage	Per-workload CVE inventory. The active assessment method, cadence, and mitigation record stay with the entity.
CIP-011	Information Protection (BCSI)	Partial Coverage	Egress report for BCSI-host workloads. Classification, storage, and disposal stay with the information-protection programme.
CIP-012	Communications between Control Centers	Partial Coverage	Observed paths and an allowlist for instrumented control-center workloads that exchange real-time data. The CIP-012 plan and link protection stay with the entity. Secure Workload does not encrypt that link.
CIP-013	Supply Chain Risk Management	Partial Coverage	Vendor-egress flows reconciled to the vendor register. The supply-chain plan and contract clauses stay with procurement.
CIP-014	Physical Security	Evidence	Transmission-

Standard	Topic (transmission)	Coverage	What to file
		Required	station physical security. No Secure Workload artifact.
CIP-015	Internal network security monitoring	Partial Coverage	East-west flow and process telemetry on instrumented IT-side hosts. Confirm the effective date for the entity's impact rating. OT segments still need the OT monitoring stack.

How to read the coverage column. Full Coverage means the export from instrumented IT-side workloads is the artifact for that requirement. Partial Coverage means Secure Workload supplies one slice and the entity files it beside another control. Evidence Required means Secure Workload produces no record for that requirement. None of these ratings is a finding that the Registered Entity is compliant.

Where CSW fits — the short version. CSW is the segmentation and visibility layer for the **IT estate** that surrounds, supports, and crosses the boundary into ESPs. The Cyber Assets *inside* the ESP (particularly Level 0–2 OT devices) typically remain under your ICS/SCADA cybersecurity stack and the network-firewall-as-EAP arrangement at the ESP boundary. CSW supplements that arrangement on the IT side: it segments the EACMS (jump hosts, AD, PKI, vendor-access servers), it enforces deny-by-default for the corporate-IT-to-ESP path, it produces CIP-007/010 evidence at workload granularity, and it monitors BCSI-hosting systems under CIP-011.

Where CSW does not fit. CSW is not certified as an EAP, is not an ICS-aware deep-packet-inspection engine for protocols like DNP3, IEC 61850, or Modbus, and does not enforce policy on the OT devices themselves. Your firewall vendor's EAP and your OT-specific monitoring (Claroty, Nozomi, Dragos, Cisco Cyber Vision, etc.) remain the primary controls there. CSW's role is the IT-side companion.

2. CIP-002 — BES Cyber System Categorization

CIP-002 R1 requires identification of BES Cyber Systems and impact rating per Attachment 1 (High / Medium / Low). The output is the authoritative scope for everything in CIP-003 through CIP-013.

CSW does not perform CIP-002 categorisation. That is a risk-and-engineering decision driven by Attachment 1 criteria (generation MW thresholds, blackstart, control centres, etc.). CSW *does* host the labels that downstream CIP processes rely on.

CSW Implementation:

Step 1: Receive the categorisation outputs from CIP-002 owners

- Per Cyber Asset: bes_impact = high | medium | low
- Per BES Cyber System: bcs_id, bcs_name, bcs_function

Step 2: Apply consistent labels to every CSW-managed workload that either **is** a CIP-relevant Cyber Asset or **supports** one (EACMS, PACS, PCA, BCSI host)

CSW UI → Inventory → Bulk Label

Mandatory labels:

bes_impact: high | medium | low | n/a
bes_role: bcs | eacms | pacs | pca | bcsi-host | corporate-it
bcs_id: [reference to your CIP-002 register entry]
esp_member: true | false
facility: [station/plant name]
region: [Regional Entity scope: WECC | NPCC | RF | SERC | TRE | MRO]

Step 3: Build CSW Scopes per (region, facility, bes_role)

CSW UI → Organize → Scopes → New

→ Recommended hierarchy:

```
Root
├── BES-Estate
│   ├── EACMS
│   │   ├── Jump-Hosts
│   │   ├── Vendor-Access-Hosts
│   │   ├── Identity-and-PKI
│   │   └── Patch-Repositories
│   ├── BCSI-Hosts
│   │   ├── Engineering-Workstations
│   │   ├── Historians
│   │   └── Document-Repositories
│   ├── PACS-Supporting-IT
│   └── Corporate-IT (everything else, default-deny target)
```

Step 4: Validate scope membership against the CIP-002 register

- Cross-check CSW count vs. the register; reconcile any delta with the BES Cyber System Asset Owner before formal sign-off

Evidence: Per-scope membership snapshot (CSV) with workload identity, OS, owner, BCS reference, ESP membership flag, and last- seen timestamp. This becomes the IT-side companion to your CIP-002 identification list.

3. CIP-005 R1 — Electronic Security Perimeter (ESP) Boundary

CIP-005 R1 requires the ESP to surround every Cyber Asset designated as part of a BES Cyber System (per the applicability matrix). Communication crossing the ESP must be through documented Electronic Access Points (EAPs), and only if necessary.

Architectural reality. Your ESP boundary firewalls (the EAPs) remain the controlling artefact for the ESP perimeter itself. CSW contributes by ensuring *the IT-side of that boundary is itself segmented*, so that a compromised corporate-IT host cannot reach the EAP from an undocumented direction.

CSW Implementation — IT-side ESP enclave segmentation:

Step 1: Define the IT-side ESP enclave policy workspace

CSW UI → Defend → Segmentation → New Workspace

Name: nerc-cip-esp-it-side-{facility}

Scope: facility = {facility} AND bes_role IN (eacms, bcsi-host)

Step 2: Compute the as-observed baseline via ADM

Run ADM ≥ 14 days; capture month-end maintenance windows

Reject "noise" clusters; rename clusters to BES-relevant roles

Step 3: Layer CIP-aligned hardening rules on top of the baseline

DENY: Corporate-IT → EAP-IP-set

(only documented hosts may reach the EAP firewall pair)

DENY: Corporate-IT → BCSI-hosts

(engineering workstations and historians get a managed

gateway)

DENY: EACMS → Internet

(jump hosts, AD, PKI never directly egress to the public internet)

ALLOW: Vendor-Access-Hosts → vendor-allowlisted FQDNs only

(covers CIP-013 R1.2.5 and R1.2.6 vendor remote access path)

LOG: Any unmatched flow inbound to EACMS or BCSI-hosts

(becomes a CIP-008 candidate event)

Step 4: Run in Simulation for ≥ 30 days

→ Resolve every legitimate-but-blocked flow with the asset owner; document each exception in the workspace notes for the audit trail referenced from CIP-005 R1.5.

Step 5: Promote to Enforce; gate by change-management approval

→ Each subsequent change captured in CSW change history; this is the IT-side complement to your CIP-005 R1 documentation.

Evidence: (a) workspace export per facility; (b) simulation → enforcement transition log; (c) quarterly enforcement diff report delivered to the CIP Senior Manager.

4. CIP-005 R2 — Interactive Remote Access (IRA)

CIP-005 R2 requires IRA to terminate at an Intermediate System with multi-factor authentication and encryption. The Intermediate System is itself a Cyber Asset and inherits the protections of its impact rating.

CSW Implementation — Intermediate System enforcement:

Step 1: Identify the Intermediate System(s) in CSW

→ Apply label: `ira_intermediate = true; bes_role = eacms`

Step 2: Build the IRA-only ingress policy

ALLOW: `{your-MFA-VPN-pool} → ira_intermediate = true`
(port 443 / 22 / 3389 as documented)

DENY: `Any → ira_intermediate = false` (when accessed via the IRA path)

Step 3: Build the IRA-only egress policy from the Intermediate System

ALLOW: `ira_intermediate = true → {documented BES Cyber Asset set}`
(port + protocol per the CIP-005 R2 Part 2.2 documentation)

DENY: `ira_intermediate = true → Internet`
(no direct internet from a jump host; covers CIP-005 R2.2)

Step 4: Capture session telemetry for forensics

→ CSW retains every flow with byte counts and process attribution
→ Pair with your IRA recording solution (Bastion logs, terminal recording) – CSW is the network-side complement, not a session recorder

Step 5: Schedule weekly IRA-pattern review

→ Generate report: every flow originating from `ira_intermediate = true`

grouped by destination workload, port, and observation count

→ CIP-005 R2 evidence: artefact dated within the audit window

Evidence: (a) IRA workspace policy export; (b) weekly IRA-flow report; (c) any anomaly events from the unmatched-flow log.

5. CIP-007 R1 — Ports and Services

CIP-007 R1.1 requires that for every applicable Cyber Asset, only network-accessible logical ports and services that are needed are enabled.

CSW Implementation:

Step 1: Inventory observed listening services per workload

CSW UI → Investigate → Inventory → Workload → Open Ports

→ For each EACMS / BCSI-host:

Listening port set

Process bound to each port
Network reachability scope (who currently reaches it)

Step 2: Cross-reference against CIP-007 R1.1 baseline

- For every observed listening port, confirm:
 - (a) it's in the documented baseline;
 - (b) it's actually used (CSW shows last-flow timestamp);
 - (c) the source set is intentional and documented.

Step 3: Generate the quarterly evidence pack

- CSW report: per-workload listening-port inventory with last-observed-flow timestamp
- Ports with no flow in 90+ days = candidate for closure under R1.1; route to Cyber Asset Owner for review.
- Ports with unexpected source set = candidate exception or misconfiguration; raise as CIP-007 R2 patching/configuration finding before audit.

Step 4: Enforce port-level allowlist where possible

- For EACMS not requiring broad reachability, add CSW policy that explicitly allows only the documented source set per port; deny everything else with audit logging.

Evidence: (a) per-workload listening-port inventory dated quarterly; (b) source-set policy for each documented port; (c) delta report between quarters.

6. CIP-007 R3 & R4 — Malicious Code Prevention and Security Event Monitoring

CIP-007 R3 requires deployment of methods to deter, detect, or prevent malicious code. R4 requires logging of security events at the Cyber Asset level (or the BES Cyber System level for low-impact).

CSW Implementation:

Step 1: Enable behavioural / process-based detections on CSW-managed workloads

CSW UI → Defend → Forensics → Rules

- Out-of-the-box rules: privilege escalation, persistence, lateral movement, suspicious child processes

- Custom rules: encode CIP-relevant abuse patterns

Example: "Process on EACMS host writes to startup paths"

Example: "Outbound to non-allowlisted FQDN from BCSI host"

Example: "Execution of new binary not in baseline on jump host"

Step 2: Wire alerts to the SOC and to the CIP-008 incident process

CSW UI → Manage → Data Tap → SIEM

- Splunk, QRadar, Sentinel, Cisco XDR
- Tag every alert with `bes_impact` and `bcs_id` so the SOC can route per Attachment 1 impact rating.

Step 3: Retain the per-event evidence for the CIP-007 R4 retention period (90 calendar days minimum unless your Regional Entity directs longer)

- CSW keeps full flow + process context; export weekly to your long-term log store.

Step 4: Map detection-to-control coverage explicitly

- CSW behavioural rule set → CIP-007 R3.1 (deter), R3.2 (detect), R3.3 (prevent – via simulation→enforce policy progression)
- Document the mapping; this is the artefact your auditor will accept as your "method" under R3.

Evidence: (a) detection rule catalogue with last-modified dates and CIP control coverage; (b) SIEM forwarding configuration screenshot; (c) sample alert with full forensic context for at least one event per quarter.

7. CIP-008 — Incident Reporting and Response Planning

CIP-008-6 R1.4 requires identification, classification, and response plans for Cyber Security Incidents. R2 and R3 cover testing and review. R4 added the reportable Cyber Security Incident notification requirement.

CSW Implementation — Incident Reconstruction Bundle:

For each Cyber Security Incident on a CSW-managed workload, assemble:

- (a) Affected workload set
 - Inventory query: hostnames, IPs, OS, BCS labels, ESP membership
- (b) Time-anchored flow record
 - CSW historical conversations: source, destination, port, byte counts, timestamps, process attribution
- (c) Process activity record
 - Every process spawned on affected workloads in the window
- (d) Software footprint at time of incident
 - Package list, CVE exposure at that moment (not "today")
- (e) Containment evidence
 - Quarantine policy applied; flow drop count after policy; time-to-quarantine

- (f) Configuration baseline diff
 - CIP-010 R1.5 unauthorised-change candidate evidence

These six artefacts populate the incident dossier your CIP-008 process and your E-ISAC notification (when applicable under R4) will draw from.

Evidence: (a) standard incident dossier template; (b) MTDD/MTTR metrics by impact rating; (c) annual aggregate incident-trend report for the CIP Senior Manager (CIP-003 R1.1 input).

8. CIP-010 — Configuration Change Management & Vulnerability Assessments

8.1 R1 — Configuration Change Management

CIP-010-4 R1.1 requires a baseline configuration including operating system or firmware (R1.1.1), commercially-installed software (R1.1.2), custom-installed software (R1.1.3), logical network-accessible ports (R1.1.4), and security patches (R1.1.5). R1.5 requires monitoring for unauthorised change.

CSW Implementation:

Step 1: Capture the baseline per CSW-managed workload

- CSW UI → Investigate → Inventory → Workload → Software & Packages
- Auto-captured: OS, kernel, package list, version, install date
- Schedule daily snapshot to CSW data tap or external store

Step 2: Add the CIP-010 R1.1.4 ports view to the same baseline

- CSW already inventories listening ports per workload (see §5)
- Snapshot the listening-port state alongside the package list

Step 3: Detect unauthorised change (R1.5)

- CSW report: daily diff between today and yesterday's package list
- CSW report: daily diff in listening ports
- Each diff routes to:
 - Authorised? → record as expected change in your CMR
 - Unauthorised? → CIP-010 R1.5 evidence + CIP-008 candidate

Step 4: Tie the change record back to your change-management ticket

- Correlate the CSW-detected change timestamp against your CM ticketing system (Remedy/ServiceNow/etc.); orphan changes are the unauthorised-change candidates.

Evidence: (a) baseline export per workload (R1.1); (b) daily diff log with disposition (authorised vs. unauthorised); (c) quarterly summary delivered to the CIP Senior Manager.

8.2 R3 — Vulnerability Assessments

CIP-010-4 R3.1 (active VA on Highs every 15 calendar months; paper VA on Mediums and Lows on different cadences per Part 3) and R3.2 (prior to commissioning Highs/Mediums) define the VA programme.

CSW Implementation:

Step 1: Continuous CVE inventory at workload level

CSW UI → Investigate → Vulnerability Report

- Per-workload CVE list with CVSS, exploit availability, EPSS score
- Filter by `bes_impact = high` → highest-priority remediation queue

Step 2: Generate the active-VA evidence (R3.1) for High-impact assets

- Quarterly CVE export tied to remediation ticket IDs
- Includes: discovery date, severity, exploit-in-the-wild status, patch availability, applied-by date

Step 3: Generate the paper-VA evidence (R3.1) for Medium-impact assets

- CSW vulnerability inventory exported on the documented cadence; the paper review combines this with vendor advisories you track out of band

Step 4: Pre-commissioning VA (R3.2)

- For new High/Medium-impact workloads, run CSW first-sighting inventory before connection to the ESP
- Export VA result; gate connection on remediation or accepted-risk documentation

Evidence: (a) per-asset CVE list dated to satisfy R3.1 cadence; (b) remediation tracking with ticket IDs; (c) pre-commissioning VA artefact per new asset.

9. CIP-013 — Supply Chain Risk Management (IT-side)

CIP-013-2 R1 requires a documented supply chain cyber security risk management plan. R1.2 covers procurement, R1.2.5 covers vendor remote access, R1.2.6 covers coordination of vendor responses to incidents.

Where CSW fits. CSW gives you the *technical evidence* layer for the vendor remote access portion (R1.2.5) and for ongoing vendor egress monitoring on the IT side. The procurement and contractual elements (R1.1, the bulk of R1.2) remain governance/legal work.

CSW Implementation:

Step 1: Enumerate every vendor-egress destination from EACMS workloads

CSW UI → Investigate → Flow Search

Filter: `source_scope < EACMS AND destination_ip ∉ internal_ranges`

- Group by destination FQDN/IP; rank by byte count, frequency
- Output: technical view of vendor dependency per EACMS host

Step 2: Reconcile against your vendor register

- For each observed external endpoint, find the corresponding vendor in your CIP-013 R1 register; flag missing endpoints

Step 3: Enforce egress allowlisting for vendor-access hosts

- ALLOW: vendor-access-hosts → {register-listed vendor endpoints}
- DENY: vendor-access-hosts → all other external destinations
- New vendor usage now requires register update before deployment

Step 4: Continuous monitoring

- CSW alert: "new external destination from EACMS host"
- Routes to the supply-chain risk owner for register reconciliation

Evidence: (a) per-EACMS vendor-egress report; (b) register-vs- observed delta report; (c) egress policy enforcement diff history.

Caveat. A vendor's *internal* posture is out of scope for CSW unless the vendor also runs CSW within their environment. CIP-013 contractual provisions remain the primary control for vendor behaviour outside your perimeter.

10. CIP-011 — Information Protection (BCSI)

CIP-011-3 protects BES Cyber System Information (BCSI) — typically network diagrams, configuration files, vulnerability assessment results, security plans, and similar artefacts. The 2022 revision (CIP-011-3) expanded protections to BCSI in third-party-hosted storage.

CSW Implementation:

Step 1: Identify BCSI-hosting workloads

- Document repository servers, SharePoint, internal wikis hosting network diagrams, config archives, VA results
- Apply label: bes_role = bcsi-host

Step 2: Egress monitoring on BCSI hosts

- CSW continuous flow analysis: every outbound from a BCSI-host workload, grouped by destination + byte volume
- Alert on any new external destination

Step 3: Access pattern monitoring on BCSI hosts

- Detect unusual access volumes (large pulls, off-hours, unusual source identities)
- Pair CSW telemetry with your DLP/identity stack – CSW is the network-side complement, not the data-classification engine

Step 4: For cloud-hosted BCSI (CIP-011-3 R1.2 scope), use CSW Cloud Connectors to inventory access patterns to the cloud storage endpoint from your IT estate

Evidence: (a) BCSI-host inventory; (b) egress pattern report; (c) anomaly alert log with disposition.

11. Mapping Table — NERC CIP Standard → CSW Capability

Standard / Requirement	Requirement summary	CSW capability (IT-side)
CIP-002 R1	BES Cyber System identification	Inventory + scope labelling for the IT estate supporting BCS
CIP-003 R1	Senior Manager accountability	Quarterly evidence pack covering §3, §5, §6, §8, §9 outputs
CIP-005 R1	ESP boundary	IT-side enclave segmentation (§3); deny-by-default to EAP IPs
CIP-005 R2	Interactive Remote Access	Intermediate-system enforcement + IRA-flow review (§4)
CIP-007 R1	Ports and services baseline	Per-workload listening-port inventory with last-flow timestamp (§5)
CIP-007 R2	Patch management	Vulnerability dashboard with CVE/CVSS/EPSS context (§8.2)
CIP-007 R3	Malicious code prevention	Behavioural rules + simulation → enforce policy (§6)
CIP-007 R4	Security event monitoring	Process + flow telemetry to SIEM with retention (§6)
CIP-007 R5	System access control	Policy limiting workload paths to authentication services. Accounts and MFA stay with identity
CIP-008 R1	Incident response plan	Six-artefact reconstruction bundle (§7)
CIP-008 R4	Reportable incident notification	Containment evidence + dossier supports E-ISAC notification
CIP-010 R1	Configuration baseline	Daily software + ports

Standard / Requirement	Requirement summary	CSW capability (IT-side)
		baseline + diff (§8.1)
CIP-010 R3	Vulnerability assessment	Continuous CVE inventory + cadence-based export (§8.2)
CIP-011 R1	BCSI protection	Egress and access monitoring on BCSI-hosts (§10)
CIP-012 R1	Control-center communications	Observed flows and an allowlist between instrumented control-center workloads. Link protection and the CIP-012 plan stay with the entity
CIP-013 R1	Supply chain risk	Vendor-egress allowlist + register reconciliation (§9)
CIP-015	Internal network security monitoring	East-west flow and process telemetry on instrumented IT-side hosts. Confirm applicability and effective date before citing it in an audit

12. Auditor / RSAW Response Guide

When the Regional Entity asks for evidence under the Reliability Standard Audit Worksheet (RSAW) for the standards above:

Auditor asks	You provide
"Show your scope of CSW deployment relative to CIP-002 categorisation"	Per-scope inventory snapshot with <code>bes_impact</code> and <code>bcs_id</code> labels (§2)
"Demonstrate IT-side controls for the ESP boundary"	Workspace export + simulation → enforcement log (§3)
"Provide IRA evidence for the audit window"	Weekly IRA-flow report bundle (§4)
"Show CIP-007 R1.1 ports baseline for these assets"	Per-workload listening-port inventory dated within the period (§5)
"Show CIP-010 R1.5 unauthorised-	Daily diff log with disposition column

Auditor asks	You provide
change monitoring"	(§8.1)
"Provide the active VA for High-impact assets"	Vulnerability export for the period with remediation tracking (§8.2)
"Show your CIP-013 R1.2.5 vendor remote-access controls"	Vendor-egress allowlist policy + observed-vs-register delta (§9)
"Reconstruct the timeline for incident X"	Six-artefact incident dossier (§7)

13. Related Frameworks

NERC CIP shares substantial control surface with:

- **NIST SP 800-53 Rev 5** — most NERC CIP requirements have direct 800-53 analogues (AC-3, AC-4, SC-7, SI-4, RA-5, CM-2, CM-3, CM-7, AU-2, IR-4 cover the bulk of CIP-005/007/008/010). See [800-53 reference design](#).
- **NIST SP 800-207 (ZTA)** — the deny-by-default, identity-aware, observability-driven posture in §3, §4, and §6 implements the seven ZTA tenets in the NERC CIP context. See [800-207 reference design](#).
- **NIST SP 800-82 Rev 3** (*out of repository scope but worth pairing externally*) — guide to OT security; CSW addresses the IT estate around the OT footprint that 800-82 describes.
- **ISO/IEC 27001:2022** — entities operating under both ISO 27001 and NERC CIP can re-use Annex A.8 evidence. See [ISO 27001 reference design](#).
- **TSA Pipeline Security Directive** — sister sector framework for pipelines; identical IT-side patterns apply. See [TSA Pipeline reference design](#).

14. Disclaimer

This reference design is **draft v1** describing how Cisco Secure Workload capabilities can support a NERC CIP programme on the IT side of the IT/OT boundary. It is **not** legal or regulatory advice and does not constitute a finding of compliance. Specifically:

- Final identification and categorisation of BES Cyber Systems (CIP-002), the design of ESP and EAP arrangements (CIP-005), determination of impact ratings (Attachment 1), and the formal CIP audit response remain the responsibility of the Registered Entity's CIP Senior Manager and qualified compliance counsel.
- CSW does not enforce policy on PLCs, RTUs, IEDs, HMIs, or any other Level 0–2 OT device, and is not certified as an Electronic Access Point (EAP).
- Always validate against the **current effective revision** of each CIP standard published on the NERC web site, against your Regional Entity's audit guidance, and against any FERC orders amending applicability or compliance dates.

This document should receive subject-matter-expert review for both NERC CIP regulatory accuracy and current Cisco product capability before being relied upon in a formal compliance engagement.